

Marco integrativo GQM + PRAGMATIC para indicadores TLPT

Objetivo: conectar los objetivos estratégicos nacionales de ciberresiliencia bajo DORA/TLPT con métricas operativas, evaluadas con el filtro PRAGMATIC (Predictivo, Relevante, Accionable, Genuino, Significativo, Preciso, Oportuno, Independiente, Rentable).[web:16]

1. Enfoque general

- GQM (Goal – Question – Metric)
- Goal: metas de resiliencia a nivel país/sector/entidad (ej. “mejorar la detección temprana de ataques avanzados”).
- Question: preguntas que permiten saber si nos acercamos a la meta (ej. “¿con qué rapidez detectamos actividades TLPT realistas?”).

Metric: datos concretos y medibles que responden a la pregunta (ej. MTTD en horas).[web:36]

PRAGMATIC

Cada métrica se evalúa en nueve criterios, típicamente en escala 0–3:

- P – Predictiva (anticipa resultados futuros).
- R – Relevante (para los objetivos TLPT/DORA).
- A – Accionable (guía decisiones y acciones).
- G – Genuina (difícil de manipular, refleja la realidad).
- M – Significativa (interpretable y útil).
- P2 – Precisa (definición y cálculo claros).
- T – Oportuna (disponible cuando hace falta).
- I – Independiente (no redundante con otras métricas).
- C – Rentable (beneficio $\geq$ coste de obtenerla).

Metric: datos concretos y medibles que responden a la pregunta (ej. MTTD en horas).[web:36]

PRAGMATIC

Cada métrica se evalúa en nueve criterios, típicamente en escala 0–3:

Escala sugerida: 0 = muy débil, 1 = aceptable, 2 = buena, 3 = excelente.

2. Catálogo de objetivos (Goal) – Nivel nacional / sectorial

A modo de ejemplo, se definen 5 metas macro que se traducen en indicadores TLPT:

- G1: Aumentar la cobertura de TLPT sobre funciones críticas de negocio y servicios TIC relevantes.
- G2: Mejorar la capacidad de detección y respuesta ante ataques avanzados (MTTD/MTTR).
- G3: Reducir la recurrencia y severidad de hallazgos críticos/altos derivados de TLPT.
- G4: Integrar TLPT en la gobernanza y planificación plurianual de resiliencia digital bajo DORA.
[web:26]
- G5: Optimizar el coste–beneficio (ROI) de los ejercicios TLPT y de las remediaciones asociadas.

3. Indicadores TLPT seleccionados y estructura GQM

A continuación se detallan los principales indicadores del informe TLPT previo, en estructura GQM.

3.1 Indicadores de cobertura y alcance (G1)

Métrica M1 – Cobertura de funciones críticas

- Goal (G1): Asegurar que las funciones críticas de negocio quedan adecuadamente ejercitadas por TLPT para reducir el riesgo sistémico.[web:16]
- Question Q1.1: ¿Qué proporción de las funciones críticas identificadas se incluye realmente en el alcance del TLPT?
- Metric M1:
- Definición: $\% \text{ Funciones críticas cubiertas} = \left(\frac{\text{n}^{\circ} \text{ funciones críticas incluidas en el último TLPT}}{\text{n}^{\circ} \text{ total de funciones críticas identificadas en el BIA bajo DORA}} \right) * 100$.
- Unidad: %.
- Fuente de datos: inventario de funciones críticas, documentos de alcance TLPT, BIA.

Métrica M2 – Cobertura de servicios TIC de terceros

- Goal (G1): Garantizar que la dependencia de terceros TIC críticos se pone a prueba de manera suficiente.[web:39]
- Question Q1.2: ¿Hasta qué punto el TLPT incluye servicios TIC de terceros que soportan las funciones críticas?
- Metric M2:
- Definición: $\% \text{ servicios TIC críticos en alcance} = \left(\frac{\text{n}^{\circ} \text{ servicios TIC críticos incluidos}}{\text{n}^{\circ} \text{ total de servicios TIC críticos identificados}} \right) * 100$.
- Unidad: %.
- Fuente de datos: registro de terceros TIC, alcance TLPT, contratos críticos.

Métrica M3 – Uso de entornos de producción

- Goal (G1): Asegurar que las pruebas TLPT se realizan en condiciones realistas, según DORA y TIBER-ES.[web:16][web:38]
- Question Q1.3: ¿Qué grado de uso de entornos de producción tiene el TLPT?
- Metric M3:
- Definición: indicador categórico (0 = solo pre-producción; 1 = mixto; 2 = solo producción).
- Unidad: índice 0–2.
- Fuente: plan de prueba, acuerdos con áreas de operación.

3.2 Indicadores de metodología y ejecución (G1, G2)

Métrica M4 – N° de escenarios TTI ejercitados

- Goal (G1, G2): Alinear TLPT con amenazas reales mediante escenarios basados en TTI.[web:31]
[web:38]
- Question Q2.1: ¿Cuántos escenarios de amenaza definidos en la fase TTI se ejercitan realmente en el TLPT?
- Metric M4:
- Definición: número absoluto de escenarios TTI ejecutados.
- Unidad: n°.
- Derivada M4b: $\% \text{ escenarios ejercitados} = \text{escenarios ejercitados} / \text{escenarios definidos} * 100$.

Métrica M5 – Duración de la fase de Red Team

- Goal (G2): Garantizar que la ventana de Red Team es suficiente para emular adversarios avanzados (≥ 12 semanas).[web:16]
- Question Q2.2: ¿Cumple la duración de la fase activa de Red Team las referencias del RTS?
- Metric M5:
- Definición: Duración RT = n° de semanas entre inicio y fin de actividades ofensivas activas.
- Unidad: semanas.

3.3 Indicadores de detección y respuesta (G2)

Métrica M6 – MTTD TLPT

- Goal (G2): Reducir el tiempo medio de detección de actividades maliciosas (MTTD).
- Question Q2.3: ¿En cuánto tiempo detecta la organización las actividades del Red Team durante el TLPT?
- Metric M6:
- Definición: $MTTD_TLPT = \text{tiempo medio (en horas) entre el inicio de actividades relevantes del Red Team y el primer evento de detección válida}$.
- Unidad: horas.
- Segmentación opcional: por tipo de TTP, vector inicial, función crítica.

Métrica M7 – Cobertura de detección (% acciones detectadas)

- Goal (G2): Aumentar el porcentaje de acciones del Red Team que son detectadas por los mecanismos de defensa.
- Question Q2.4: ¿Qué proporción de las actividades ofensivas del TLPT fueron detectadas por el Blue Team?
- Metric M7:
- Definición: $\% \text{ acciones detectadas} = (\text{n° acciones del Red Team con evidencia de detección} / \text{n° total de acciones relevantes}) * 100$.
- Unidad: %.

Métrica M8 – MTTC / MTTR TLPT

- Goal (G2): Reducir el tiempo de contención y recuperación frente a incidentes simulados.
- Question Q2.5: ¿Cuánto tarda la organización en contener y restaurar servicios durante el TLPT?
- Metric M8a – MTTC:
 - Definición: tiempo medio entre detección y primera acción efectiva de contención.
 - Unidad: horas.
- Metric M8b – MTTR:
 - Definición: tiempo medio entre el impacto sobre el servicio crítico simulado y el restablecimiento a niveles aceptables.
 - Unidad: horas/días.[web:26]

3.4 Indicadores de hallazgos y remediación (G3)

Métrica M9 – Tasa de hallazgos por criticidad

- Goal (G3): Reducir el número de hallazgos críticos/altos producto de TLPT.
- Question Q3.1: ¿Cuál es el volumen y la proporción de hallazgos críticos/altos en el TLPT?
- Metric M9:
 - Definición: N° hallazgos críticos/altos, N° hallazgos totales, % críticos/altos.
 - Unidad: n° y %.

Métrica M10 – Remediación en plazo

- Goal (G3): Aumentar el porcentaje de hallazgos críticos/altos remediados en plazo (p.ej. ≤8 semanas).
- Question Q3.2: ¿Cuántos hallazgos críticos/altos se remediaron en el plazo objetivo?
- Metric M10:
 - Definición: % remediación en plazo = (n° hallazgos críticos/altos con plan implementado en ≤X semanas / n° total hallazgos críticos/altos) * 100.
 - Unidad: %.[web:16]

Métrica M11 – Recurrencia de hallazgos

- Goal (G3): Evitar la repetición de vulnerabilidades previamente identificadas.
- Question Q3.3: ¿Qué porcentaje de hallazgos TLPT son reincidentes respecto a ejercicios anteriores?
- Metric M11:
 - Definición: % hallazgos recurrentes = (n° hallazgos TLPT que ya estaban en TLPT/auditorías previas / n° total de hallazgos TLPT) * 100.
 - Unidad: %.

3.5 Indicadores de gobernanza y planificación (G4)

Métrica M12 – Cumplimiento de ciclo trienal TLPT

- Goal (G4): Cumplir la frecuencia mínima de TLPT (cada 3 años) y asegurar planificación.[web:16]
- Question Q4.1: ¿Realiza la entidad al menos un TLPT completo en cada ciclo trienal?
- Metric M12:
- Definición (entidad): indicador binario (1 = sí, 0 = no).
- Derivada (país): $\% \text{ entidades en ciclo} = \left(\frac{\text{nº entidades con al menos un TLPT en 3 años}}{\text{nº entidades obligadas}} \right) * 100$.

Métrica M13 – Existencia de plan plurianual de pruebas avanzadas

- Goal (G4): Integrar TLPT en un programa plurianual de pruebas de resiliencia digital.
- Question Q4.2: ¿Existe un plan plurianual formal que integre TLPT/TIBER-ES y otras pruebas avanzadas?
- Metric M13:
- Definición: índice de madurez 0–3 (0 = no existe; 1 = borrador; 2 = plan aprobado; 3 = plan aprobado + revisado anualmente).
- Unidad: 0–3.[web:26]

3.6 Indicadores de impacto económico / ROI (G5)

Métrica M14 – Coste total TLPT

- Goal (G5): Medir el coste real de TLPT (ejercicio + remediación inicial).
- Question Q5.1: ¿Cuánto cuesta, de forma integral, el ciclo TLPT (ejecución + remediación)?
- Metric M14:
- Definición: $\text{Coste_TLPT} = \text{coste ejercicio (proveedores + tiempo interno)} + \text{coste acciones de remediación prioritarias}$.
- Unidad: euros.

Métrica M15 – Estimación de pérdidas evitadas

- Goal (G5): Estimar, con prudencia actuarial, las pérdidas esperadas evitadas por la mejora de controles tras TLPT.[web:26]
- Question Q5.2: ¿Qué volumen de pérdidas esperadas se reduce atribuible a las acciones de remediación TLPT?
- Metric M15:
- Definición: $\text{Perdidas_Previstas_Evitadas}$ estimadas mediante modelos de riesgo operativo (frecuencia x impacto) antes/después del TLPT.
- Unidad: euros.

Métrica M16 – ROI TLPT

- Goal (G5): Evaluar el retorno económico del ejercicio TLPT en términos de pérdidas evitadas y beneficios regulatorios.
- Question Q5.3: ¿Cuál es el ROI del TLPT considerando costes y beneficios cuantificados?
- Metric M16:
- Definición: $ROI_TLPT = (Beneficio_Total - Coste_Total) / Coste_Total$, donde $Beneficio_Total = Perdidas_Previstas_Evitadas + Ahorros_Regulatorios$.
- Unidad: %.